

Encabezado: TÍTULO ABREVIADO DE HASTA 50 CARACTERES

Avance Semanal

Divier jacamo alvarez

CETAV

Rol: Analista SOC L1

Fecha 04/02/2026

Escenario de caso en clínica de salud mental

El SIEM de la Clínica Médica Integral genera una alerta de correlación que es recibida inicialmente por el Analista SOC Nivel 1.

La alerta corresponde a un inicio de sesión exitoso en el sistema de información clínica utilizando una cuenta de un usuario administrativo.

Al revisar el evento, el analista SOC Nivel 1 observa que el acceso se realiza fuera del horario habitual de trabajo del usuario y desde un punto de acceso que no coincide con sus registros históricos de conexión.

Minutos después del inicio de sesión, se registraron múltiples consultas consecutivas a expedientes clínicos de diferentes pacientes en un periodo de tiempo muy corto, además de un comportamiento anormal.

La cantidad de accesos durante las primeras horas es superior al comportamiento normal de ese usuario dentro del sistema.

Durante la misma sesión, el SIEM también registra eventos relacionados con operaciones internas sobre archivos del sistema de información clínica.

Debido a que el comportamiento observado no corresponde con dicho uso habitual del usuario y puede implicar un riesgo para la información clínica de la institución, el Analista SOC Nivel 1 documenta la alerta y eleva el caso para su análisis al Analista SOC Nivel 2.

Mi respuesta como Analista SOC 1

Como Analista SOC Nivel 1, antes de proceder con la elevación del caso, se realiza la validación inicial del incidente a partir de la alerta

Generado por el SIEM.

Primero, verifique si la alerta es real. Para hacer esto, observe los registros de cuándo alguien se conectó al sistema. Comprobamos la cuenta que está involucrada, la fecha y la hora en que alguien accedió, y el sistema que se vio afectado quiero asegurarme de que la conexión al sistema fue exitosa y que sucedió en un momento en que

el usuario normalmente no está trabajando.

Posteriormente, se revisan los registros de acceso al sistema de información clínica con el fin de confirmar la cantidad de expedientes consultados durante la sesión y el intervalo de tiempo en el que se produjeron los accesos, comprobando que el volumen de consultas es superior al comportamiento histórico del usuario.

A continuación, examinare los eventos relacionados con la sesión para encontrar actividades adicionales esto incluye comprobar si hay operaciones sobre archivos dentro del sistema clínico.

También se revisan, de forma general, los registros disponibles del equipo origen y del sistema de red para confirmar que la actividad se concentra en una única sesión y en una sola cuenta de usuario.

Finalmente, una vez confirmada la anomalía y sin realizar acciones de contención directa, el Analista SOC Nivel 1 documenta los hallazgos iniciales, clasifica el evento como incidente potencial de seguridad y procede a elevar el caso al Analista SOC Nivel 2 para su análisis especializado.

Caso Analista SOC 1 sin elevación a Analista SOC 2

El día de hoy martes se recibió una alerta en el sistema de monitoreo.

Esta alerta se debe a que se ha conectado un dispositivo USB externo a una computadora en la zona 2, la cual es la red administrativa.

Además, se han detectado procesos que no suelen ejecutarse en esa computadora; como primera acción valide la alerta en la plataforma SIEM, confirmando la hora de conexión del dispositivo USB el equipo afectado y la cuenta de usuario que se encontraba activa en la estación de trabajo.

Posteriormente revisa los registros del sistema operativo enviados al SIEM y verifica que el evento de detección del dispositivo USB coincide temporalmente con el inicio de los procesos inusuales.

El analista identifica que la actividad se origina únicamente desde una estación de trabajo de la red administrativa y que no existen, hasta ese momento, registros de accesos exitosos a los servidores de la Zona 5. Se revisan los eventos del firewall y se confirma que las conexiones desde el equipo administrativo hacia los servidores internos no se establecieron como deberían.

Se procedió a analizar los procesos con el threat intelligence del SIEM se investigó si los procesos correspondían a herramientas legítimas se procedió a documentar la coincidencia de dichas firmas

Los procesos inusuales fueron terminados y puestos en cuarentena automáticamente por políticas de seguridad

Se verifico en el directorio si dicho USB tiene un número de serie registrado por el hospital

Reporte Final en el SIEM

Se cierra la alerta como un falso positivo por actividades no autorizadas, aunque dichos procesos fueron inusuales el análisis del firewall confirmo que no salieron datos ni saltos en la zona 5 el

usuario valido sus actividades y se procedió a eliminar dichos
archivos temporales

Referencias

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide: Recommendations of the National Institute of Standards and Technology* (NIST Special Publication 800-61 Revision 2). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-61r2>

International Organization for Standardization. (2023). *Information technology — Information security incident management — Part 1: Principles and process* (ISO/IEC 27035-1:2023).

<https://www.iso.org/standard/78973.html>

Insside Ciberseguridad. (2025, 16 de junio). *Analista SOC Nivel 1: El primer paso en la respuesta ante amenazas.*

<https://www.insside.net/que-hace-un-analista-soc-de-nivel-1/>